

Clase 191 — Análisis de logs de red y proxy

Parte: 8 — Blue Team, detección y SOC · Fuente: *Applied Network Security Monitoring* — Chris Sanders y Jason Smith 🕒 Duración estimada: 110 min · Nivel: Avanzado

Objetivo

Explotar la telemetría de red —logs de firewall, proxy web, DNS y metadatos de Zeek— para detectar amenazas que el endpoint no ve o que intentan ocultarse. El monitoreo de red (NSM) es complementario al de endpoint: aunque un host esté comprometido y silencie sus logs, el tráfico que genera sigue pasando por la red.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Interpretar** logs de firewall, proxy y DNS para detección.
2. **Usar** los logs de Zeek (conn, dns, http, ssl) en hunting.
3. **Detectar** exfiltración, dominios sospechosos y user-agents anómalos.
4. **Identificar** túneles (DNS, HTTP) y tráfico cifrado sospechoso vía metadatos.
5. **Correlacionar** telemetría de red con la de endpoint.

Temas

#	Tema	Por qué importa
1	NSM: por qué la red importa	Ve lo que el host oculta
2	Logs de firewall y flujo	Volumen, direcciones, puertos
3	Proxy web y user-agents	Detecta C2 y descargas maliciosas
4	DNS: la mina de oro defensiva	DGA, tunneling, resolución rara
5	Zeek: conn/dns/http/ssl.log	Metadatos ricos sin PCAP completo
6	JA3/JA3S y fingerprint TLS	Identificar clientes sin descifrar
7	Exfiltración y beaconing (intro)	Patrones de salida anómala
8	Correlación red↔endpoint	Historia completa del incidente

Definiciones y características

- **NSM (Network Security Monitoring):** recolección y análisis de datos de red para detectar intrusiones. Característica: visibilidad independiente del host.
- **conn.log (Zeek):** registro de cada conexión con duración, bytes y estado. Característica: base para top talkers y anomalías de volumen.

- **dns.log (Zeek):** consultas y respuestas DNS. Característica: detecta DGA, tunneling y dominios recién registrados.
- **Proxy log:** peticiones web con URL, user-agent, método y respuesta. Característica: revela C2 sobre HTTP/S y descargas.
- **JA3/JA3S:** hash del handshake TLS del cliente/servidor. Característica: identifica herramientas (p. ej. ciertos C2) aun con cifrado.
- **DNS tunneling:** exfiltración/C2 encapsulados en consultas DNS. Característica: dominios largos, alta entropía, muchas subconsultas.
- **Beaconing:** conexiones periódicas y regulares a un C2. Característica: patrón temporal casi constante (se profundiza en la clase 193).

Herramientas y preparación

En laboratorio aislado con un tap/mirror:

- **Zeek** generando conn/dns/http/ssl.log.
- **Suricata** como IDS complementario para alertas de firma.
- Logs de un **proxy** (Squid) o firewall de laboratorio.
- **RITA** (Real Intelligence Threat Analytics) para analizar beaconing y tunneling sobre logs de Zeek.
- Tu SIEM para ingerir y consultar estos logs.

Captura tráfico solo de tu propia red de pruebas.

Laboratorio guiado — Caza en la telemetría de red

1. **Genera tráfico.** En la VM, navega, resuelve dominios y descarga un archivo benigno para poblar los logs.
2. **Revisa conn.log.** Identifica top talkers por bytes y conexiones a puertos poco comunes.
3. **Analiza DNS.** En dns.log, busca dominios de alta entropía o subdominios muy largos (indicio de tunneling). Marca dominios recién vistos.
4. **Inspecciona proxy/http.log.** Filtra user-agents raros (p. ej. `python-requests`, cadenas vacías) y métodos POST voluminosos.
5. **Fingerprint TLS.** En ssl.log revisa JA3; compáralo con listas conocidas de herramientas para detectar clientes anómalos.
6. **Ejecuta RITA.** Importa los logs de Zeek y corre el análisis de beaconing y DNS tunneling; interpreta el score.
7. **Simula exfiltración lenta.** Envía datos benignos en pequeños fragmentos DNS a un servidor de laboratorio y confirma que tus consultas lo detectan.
8. **Correlaciona.** Une una conexión saliente sospechosa (red) con el proceso responsable (Sysmon Event 3) del mismo host y momento.

Ejercicios

1. Escribe una consulta que liste los 10 dominios con más subconsultas únicas (posible tunneling).
2. Detecta descargas de ejecutables desde IPs sin dominio asociado.
3. Explica cómo JA3 ayuda cuando el tráfico está cifrado.
4. Diseña una detección de user-agent anómalo para tu entorno.
5. Correlaciona una alerta de red con el proceso de endpoint que la originó.

6. Interpreta un resultado de beaconing de RITA y decide si escalar.

Reto verificable

Detecta en tu laboratorio una actividad de red sospechosa (tunneling DNS o exfiltración por HTTP) usando logs de Zeek/proxy y correlaciónala con el endpoint origen. **Criterio de aceptación:** identificas el dominio/destino anómalo con una justificación basada en datos (entropía, volumen, periodicidad o fingerprint) y enlazas la conexión con el proceso concreto que la generó en el host.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No hay logs de DNS	El resolver no se registra; envía consultas al colector o usa Zeek
Todo el tráfico parece igual	Falta baseline de dominios/UA normales; modela lo habitual
JA3 no discrimina	Cliente común (navegador); combínalo con destino y volumen
PCAP satura el disco	Retención de contenido completo demasiado larga; usa metadatos Zeek
Falsos positivos de CDN	Servicios legítimos con muchos subdominios; añade allowlist

Preguntas frecuentes

? Con TLS everywhere, ¿sigue sirviendo la red? Sí. Aunque no veas la carga, los metadatos (SNI, JA3, volumen, periodicidad, DNS) delatan C2, beaconing y exfiltración. La red revela el patrón aunque el contenido esté cifrado.

? ¿DNS realmente es tan importante? Muchísimo. Casi todo ataque resuelve dominios: DGA, tunneling y C2 dejan huella en DNS. Es de las fuentes de mejor relación señal/coste.

? ¿Necesito PCAP completo? Rara vez y por poco tiempo. Los metadatos de Zeek cubren la mayoría de casos de hunting con una fracción del almacenamiento.

Referencias

- Sanders, C. y Smith, J. *Applied Network Security Monitoring*. Syngress.
- Zeek Documentation — <https://docs.zeek.org/>
- RITA — <https://github.com/activecm/rita>
- JA3 (Salesforce) — <https://github.com/salesforce/ja3>
- Suricata Documentation — <https://docs.suricata.io/>

Siguiente clase

Clase 192 - Detección de movimiento lateral